

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to distinguish the architectural differences between object storage and volume storage in cloud environments.
- By the end of this lecture, you will be able to explain how the flat namespace and API-access model of object storage affects security design.
- By the end of this lecture, you will be able to identify the unique security exposure model for volume storage, including snapshot and block-level access risks.
- By the end of this lecture, you will be able to apply the principle that access model determines security model when selecting controls for each storage type.
- By the end of this lecture, you will be able to recognize common misunderstandings about object storage that lead to architecture flaws or security gaps.

Introduction

Cloud storage has moved far beyond the familiar paradigm of hierarchical folders and mounted drives. Modern cloud platforms deliver two distinct storage types — object storage and volume storage — each with a fundamentally different access model, operational purpose, and security profile. Understanding how they differ is not merely a technical detail for architects; it is a prerequisite for building effective security controls. The CCSP examination tests candidates on both types because the threats that affect them, and the defenses appropriate for each, are genuinely different.

Object storage, typified by Amazon S3, Azure Blob Storage, and Google Cloud Storage, organizes data as a flat collection of uniquely keyed objects retrieved through HTTP-based APIs. There are no directories, no file paths, no mount points. Volume storage, represented by AWS Elastic Block Store, Azure Managed Disks, and Google Persistent Disk, delivers block-level access that allows an operating system to format and manage the storage as it would a local hard disk. These distinctions determine attack surface, access control method, and the nature of likely failures. A Cloud Security Practitioner who conflates the two risks both architectural mistakes and misconfigured defenses.

This guide reinforces the lecture's core insight: the access model determines the security model. Object storage is secured at the API and identity layer; volume storage is secured at the instance, file system, and encryption layer. Knowing which type you are working with — and which controls are therefore appropriate — is where sound cloud data security begins.

Core Concepts Explained

Object Storage Architecture and Flat Namespace

Definition: Object storage organizes data as discrete objects — each comprising the data itself, descriptive metadata, and a unique key — stored in a flat namespace with no directory hierarchy. Objects are retrieved via API calls (typically HTTP/REST), not through file-system paths.

Business relevance: Object storage underpins web applications, data lakes, media delivery, machine learning datasets, and archival workflows at massive scale. Netflix, financial institutions archiving audit logs, and organizations running distributed ML training all depend on object storage because the API-access model scales to trillions of objects without performance degradation.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you must understand that there is no network file share behavior to rely on. Controlling access to object storage means configuring identity-and-access management policies and bucket policies precisely — the API is the only doorway, and it faces the internet.

Real-world example: A global insurance company migrates its claims image archive — several hundred million TIFF files — to Amazon S3. Engineers configure a bucket with a presigned URL mechanism: authenticated users receive time-limited URLs valid for 15 minutes to retrieve specific claim images. During a post-migration security review, the practitioner notices that an older test bucket created during proof-of-concept work was set to public read. The test bucket contained sample claims documents, including redacted but still sensitive customer identifiers. Because S3's flat namespace means every object is independently addressable via its URL, any internet user who discovered the bucket endpoint could enumerate and download those documents. The practitioner revokes public access, enables S3 Block Public Access at the account level, and implements AWS Config rules that alert whenever a bucket policy grants public read to new buckets going forward.

Risks or limitations: The primary risk is misconfiguration: a bucket set to public read access exposes every object in it to the internet with no authentication required. Secondary risks include overly permissive IAM policies, hardcoded credentials in application code with access to the bucket, and absent audit logging on API calls. Best practice: enable server-side access logging or AWS CloudTrail data events for all S3 buckets, enforce Block Public Access at the organization account level, and use resource-based bucket policies with explicit deny for public principals.

Volume Storage and Block-Level Access

Definition: Volume storage provides block-level access to storage, presenting the operating system with what appears to be a raw disk. The OS formats it with a file system and manages it exactly as it would a local drive. Access is mediated by the OS and file system, not by an internet-facing API.

Business relevance: Relational database engines — MySQL, PostgreSQL, Microsoft SQL Server — require direct, consistent, low-latency access to a file system they control. This makes volume storage the appropriate choice for transactional workloads, high-throughput I/O, and any application whose architecture depends on POSIX file-system semantics.

Cloud Security Practitioner relevance: For a Cloud Security Practitioner, volume storage security shifts focus from IAM policies to encryption configuration, file-system access controls, and the security posture of the attached compute instance. Compromising the instance that holds an attached volume is often the path to the data, not a direct API attack.

Real-world example: A healthcare technology company runs its patient-records database on PostgreSQL deployed on an AWS EC2 instance with a 2 TB EBS volume. During a penetration test, the assessors

compromise the EC2 instance through an unpatched web application vulnerability. Because the EBS volume was provisioned without encryption — the team assumed the VPC network perimeter was sufficient protection — the assessors can read the raw PostgreSQL data files directly at the block level. The security team responds by enabling EBS encryption using a customer-managed KMS key, re-encrypting the existing volume by creating an encrypted snapshot and restoring from it, and instituting an SCP (Service Control Policy) that denies creation of unencrypted EBS volumes across the organization.

Risks or limitations: Key risks include unencrypted volumes attached to compromised instances (block-level data exposure), unprotected volume snapshots shared accidentally outside the account, and orphaned volumes left in a detached state after instance termination. Best practice: enforce encryption at rest for all volumes via an organizational policy, scope snapshot sharing permissions explicitly, and implement lifecycle policies that detect and flag orphaned volumes.

API Access Model as the Security Boundary for Object Storage

Definition: Because object storage is accessed entirely through an HTTP-based API rather than through a network file system or OS-controlled path, the security boundary is defined by identity and access management policies applied to the bucket and its objects. There is no network boundary between the internet and the data; the API is the perimeter.

Business relevance: This model enables global accessibility and massive scale, but it means that any credential authorizing access to the API — an IAM access key, a role assumed by a compute instance, a presigned URL — becomes a potential target. Access control errors are not local; they expose data to the entire internet.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must treat every identity that can call the object storage API as part of the threat surface. Credential hygiene (rotation, least privilege, no hardcoded keys), bucket policy auditing, and API-level monitoring are the primary controls, not firewalls or network segmentation.

Real-world example: During a DevSecOps pipeline review at a fintech company, a security engineer scans the code repositories for secrets and finds that an S3 access key ID and secret were committed to a private GitHub repository eighteen months earlier. The key had never been rotated. The key belonged to an IAM user with broad read access to the company's audit log bucket. A threat-hunting exercise reveals no evidence of exfiltration, but the key's permissions would have allowed any possessor to download the entire contents of the audit log bucket — years of transaction records — via standard AWS CLI commands with no network-based detection possible. The team revokes the key immediately, implements a mandatory secrets scanning step in the CI/CD pipeline, migrates applications from long-lived access keys to IAM roles with short-lived STS tokens, and activates GuardDuty to monitor for anomalous S3 API activity.

Risks or limitations: Risks include hardcoded credentials in code, long-lived access keys without rotation, overly permissive IAM roles, and absent API call logging. Best practice: use IAM roles with short-lived STS credentials rather than long-lived access keys, enforce key rotation policies, enable CloudTrail with S3 data event logging, and use Amazon Macie or equivalent tooling to detect anomalous data-access patterns.

Volume Snapshots as an Overlooked Exposure Vector

Definition: Volume snapshots are point-in-time backups of block storage volumes, stored as objects within the cloud provider's infrastructure. Though logically a backup of a volume, they are governed by separate, independent access control policies that may be misconfigured independently of the source volume.

Business relevance: Snapshots are essential for disaster recovery, compliance archiving, and pre-change checkpoints. However, their storage as objects with their own sharing configuration means that a protected

production volume can have a publicly accessible backup — giving attackers complete access to all data that existed on the volume at the time of the snapshot.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you must audit snapshot sharing configurations as a distinct step in storage security reviews. Assume that the volume being encrypted and correctly permissioned does not imply the snapshot is similarly protected. Research and tooling from the cloud security community have repeatedly surfaced publicly accessible snapshots containing complete database backups from organizations that believed their data was private.

Real-world example: A software company's operations team creates weekly EBS snapshots of their production database server as part of their backup strategy. During a cloud security posture management review, the security practitioner discovers that three snapshots from the previous quarter have their permissions set to 'all', making them accessible to any AWS account. The snapshots include a complete image of the database volume, which holds customer payment information and API keys for third-party services. Investigation traces the misconfiguration to a script that originally created the snapshots public-readable so that a partner company could access them, but the script was never updated after the data-sharing arrangement ended. The practitioner revokes public access on the snapshots, implements an AWS Config rule to detect and auto-remediate public snapshots, and establishes a quarterly snapshot permission audit as a standing security control.

Risks or limitations: Risks include snapshot policies set to allow sharing with unintended accounts or made public, snapshots of encrypted volumes that are shared without considering whether the target account can access the encryption key, and absent lifecycle management that accumulates old snapshots with stale, overly permissive settings. Best practice: implement detective controls via AWS Config or equivalent to alert on snapshot policy changes, apply encryption by default, and enforce snapshot lifecycle policies.

The Access-Model-Determines-Security-Model Principle

Definition: The fundamental security architecture principle governing cloud storage: the mechanism through which data is accessed determines which controls are effective. Object storage (API access) is secured through identity, policy, and monitoring. Volume storage (block/OS access) is secured through encryption, instance hardening, and snapshot governance.

Business relevance: Organizations that apply a one-size-fits-all security approach to cloud storage — for example, relying only on network segmentation, or only on encryption — will have gaps. The right controls for each type are distinct and must be applied deliberately based on the access model in use.

Cloud Security Practitioner relevance: A Cloud Security Practitioner uses this principle as a diagnostic framework during architecture reviews: first identify the storage type, then identify the access model, then ask whether the controls proposed address the specific threat surface of that access model. Controls appropriate for volume storage (disk encryption, OS hardening) are largely irrelevant if applied to an object storage bucket without accompanying IAM policy review.

Real-world example: During a cloud security architecture review for a media company, a practitioner finds that the team applied strong VPC network controls — private subnets, security groups, NACLs — to protect their Amazon S3 content delivery pipeline, but had not reviewed their bucket policies. The team believed the network controls were sufficient because they were thorough. However, because object storage is accessed through a public-facing API endpoint, VPC controls do not restrict direct API access to the bucket. An overly permissive bucket policy was allowing cross-account read from several now-inactive third-party vendor accounts. The practitioner removes the stale cross-account permissions, enables S3 Access Analyzer to identify future externally accessible resources, and conducts a training session with the team explaining why object storage requires a distinct security posture from compute-layer network controls.

Risks or limitations: The primary risk is misapplying controls: hardening the network perimeter while leaving IAM policies unchecked for object storage, or encrypting volumes while leaving snapshots open. Best practice: maintain a storage inventory that documents storage type, access model, and the specific controls applied to each, and verify controls are appropriate to the access model during every security review.

Practical Applications

The following scenarios illustrate how Cloud Security Practitioners apply the distinctions between object and volume storage to real-world security decisions, from access policy design to incident response.

Conducting a Cloud Storage Security Assessment

A Cloud Security Practitioner joining a new organization's cloud security team is asked to baseline the storage security posture. The practitioner begins by inventorying all storage resources across the cloud environment, separating object storage buckets from block volumes and snapshots. For each object storage bucket, the practitioner reviews bucket policies and access control lists for public access grants, cross-account sharing, and IAM permissions. They use the cloud provider's access analyzer tools to surface any resources with externally accessible policies. For volume storage, the review focuses on encryption status — verifying that all volumes are encrypted, identifying the key management model in use, and confirming that snapshots are encrypted and have restricted sharing settings. The practitioner also identifies orphaned volumes: detached EBS volumes that have no active attachment and no recent snapshot activity. The output is a prioritized remediation list, with publicly accessible buckets and unencrypted volumes attached to production instances marked as critical. The exercise is documented as a repeatable runbook so that new account provisioning triggers an automatic baseline assessment.

Designing Least-Privilege Access for an Object Storage Data Lake

A data engineering team is building a data lake in Amazon S3 to centralize analytics datasets. The Cloud Security Practitioner is engaged early in the design process to architect the access model. Rather than granting the analytics platform a broad IAM role with S3 read access across all buckets, the practitioner recommends a resource-based bucket policy approach combined with IAM role separation: each data pipeline receives a dedicated IAM role that has access only to the specific S3 prefixes it needs, with no ListBucket permissions that would allow enumeration of the full bucket contents. Presigned URLs with 15-minute expiry are used for any human-initiated data access, eliminating the need for long-lived credentials to be distributed to analysts' workstations. S3 Object Lock is applied to the compliance archive prefix, preventing deletion or modification of archived datasets for the legally required retention period. The practitioner also configures S3 server access logging and integrates the logs with the SIEM, establishing alerting for anomalous bulk-download patterns that might indicate data exfiltration by an insider or compromised credential. The result is a data lake where each actor has the minimum access required, all access is logged, and retention requirements are enforced at the storage layer.

Responding to a Volume Snapshot Exposure Incident

A security operations analyst receives an alert from a cloud security posture management tool indicating that an EBS snapshot has been made public. The Cloud Security Practitioner leading the incident response first determines the contents of the snapshot: it is a point-in-time image of the company's CRM database volume from the prior week, containing customer contact information and sales pipeline data. The practitioner immediately revokes the public permission on the snapshot and checks whether the snapshot was recently accessed by external accounts using CloudTrail. The CloudTrail review shows two DescribeSnapshots API calls

from unrecognized accounts, but no evidence of the snapshot being shared or converted into a running volume by those accounts. The practitioner notifies the legal and privacy teams of a potential exposure, prepares a timeline for the breach notification assessment, and works with the data classification team to confirm what data was present in the snapshot. Simultaneously, the practitioner deploys an AWS Config rule to automatically revoke public snapshot permissions and alert the security team within five minutes of any future public snapshot policy change. The incident report documents the root cause — a manual snapshot creation step in an ops runbook that included a '--create-volume-permission' flag copied from an old procedure — and the runbook is updated to remove the flag and require review of sharing settings before saving.

Best Practices

- **Enable Block Public Access at the organization level for all object storage, not just individual buckets.** Cloud provider account-level settings that block public access act as a guardrail even when individual bucket policies are misconfigured. In AWS, the S3 Block Public Access setting can be applied at the account and organization levels using SCPs, preventing any bucket policy or ACL from granting public access regardless of what individual teams configure. Verify this control is active by inspecting the account-level S3 settings and confirming with an AWS Config conformance pack that checks all member accounts.
- **Enforce encryption at rest for all volumes and snapshots through organizational policy, not individual team choices.** Encryption of volume storage must not be left to individual project teams. Apply AWS SCPs or equivalent provider-level guardrails that deny the creation of unencrypted EBS volumes and unencrypted snapshots. Use the cloud provider's default encryption settings at the region level so that newly created volumes are automatically encrypted even if the requestor does not specify it. Audit existing volumes quarterly and flag any unencrypted volumes still running production workloads for immediate remediation.
- **Audit volume snapshot sharing permissions on a defined schedule, treating snapshots as independently governed resources.** Snapshot permissions are separate from the volume they back up and must be reviewed independently. Establish a weekly or monthly automated check — using AWS Config, a custom Lambda function, or a CSPM tool — that reports all snapshots with sharing permissions beyond the owning account. Any snapshot shared with specific external accounts should be mapped to a documented business justification and reviewed on expiry. Public snapshot sharing should trigger an immediate alert and automated revocation.
- **Use IAM roles with short-lived credentials rather than long-lived access keys for all object storage access by applications.** Long-lived IAM access keys for S3 access are a persistent risk because they do not expire and may be inadvertently committed to version control or left in configuration files. Migrate all application access to IAM roles that generate short-lived STS credentials (typically valid for 1–12 hours) via the instance metadata service or a secrets management solution. For human access, implement SSO-federated role assumption rather than issuing access keys. When access keys are unavoidable, enforce a maximum age of 90 days and automate rotation.
- **Implement API-level monitoring for object storage and correlate access patterns against a baseline to detect exfiltration.** Network-based DLP controls are ineffective for object storage because access occurs through the cloud provider's public API endpoint, bypassing on-premises inspection points. Enable CloudTrail data event logging for S3, ingest the logs into a SIEM, and establish alerting for anomalous patterns: bulk GetObject calls from a single identity in a short time window, GetObject calls from an unusual geographic region, or access to buckets outside the identity's normal operational scope. Amazon Macie or equivalent tooling can automate discovery of sensitive data in buckets and alert when that data is accessed unexpectedly.

Common Mistakes and Misconceptions

Misconception: Treating object storage like a network file share and applying only network-layer controls such as VPC restrictions, security groups, and NACLs to protect it.

Correct approach: Recognize that object storage is accessed through a public-facing HTTP API. VPC controls limit compute access to the API endpoint but do not restrict direct API calls. The correct defense is IAM policy hardening, bucket policy auditing, and Block Public Access enforcement at the account level — controls that operate at the identity and API layer, not the network layer.

Misconception: Assuming that because a production EBS volume is encrypted, its snapshots are equally protected.

Correct approach: Snapshot permissions are governed independently of the volume. An encrypted snapshot can still be made publicly accessible through a misconfigured permission. Apply dedicated snapshot permission auditing and use detective controls to alert on any snapshot sharing change, treating snapshots as first-class security resources.

Misconception: Using long-lived IAM access keys in application code or configuration files to authenticate against object storage APIs.

Correct approach: Long-lived keys can be committed to version control, stored in unsecured configuration files, or stolen from application environments. Use IAM roles attached to compute instances or Lambda functions, which provide short-lived STS credentials automatically rotated by the platform, eliminating the need to distribute or manage static keys.

Misconception: Leaving orphaned volumes in a detached state without assessing whether they contain sensitive data or enforcing a lifecycle disposition policy.

Correct approach: Detached volumes retain their data and may be re-attached to future instances — potentially by unintended teams or in merged/acquired account environments. Implement automated detection of detached volumes, classify them based on the originating workload, and either re-attach, snapshot and delete, or encrypted-wipe-and-delete within a defined SLA.

table: Object vs. Volume Storage: Security Controls Reference

Use this comparison table during architecture reviews and storage security assessments to ensure controls are matched to the correct access model.

Attribute	Object Storage (S3, Blob, GCS)	Volume Storage (EBS, Managed Disks, PD)
Access model	HTTP API (REST/PUT/GET), public endpoint	Block I/O via OS, attached to compute instance
Primary security boundary	IAM policies and bucket policies	OS access controls, encryption, instance security
Encryption standard	Server-side (AES-256), enabled by default since 2023 (AWS S3)	Encryption at rest (AES-256), must be enforced via policy
Snapshot / backup risk	ACLs on object copies or exported data	Snapshot sharing permissions (independent of volume)
Access logging	Server access logs, CloudTrail data events	OS-level audit logs, CloudTrail for API operations
Public exposure risk	Bucket set to public-read (high impact)	Lower direct risk, but compromised instance = block access

Least-privilege control	Resource-based bucket policies, IAM least-privilege roles	OS user permissions, IAM for API operations on volume
Monitoring tool example	Amazon Macie, CloudTrail S3 data events	AWS Config, CloudTrail, EC2 instance monitoring

How to use this: Review this table when selecting controls for any storage resource. Confirm you have addressed the primary security boundary column for each storage type in scope.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A security architect is reviewing access controls for a company's data lake stored in Amazon S3. The architecture team states that the VPC security groups and NACLs are tightly configured. Which statement best describes the security gap this posture presents?

- A) A. VPC controls are sufficient because S3 API calls are routed through VPC endpoints by default.
- B) B. VPC controls do not restrict direct API calls to S3 since S3 is accessed through a public API endpoint, and bucket policies must be reviewed separately.
- C) C. Security groups automatically apply to S3 bucket access when the bucket is in the same region as the VPC.
- D) D. The VPC controls are redundant because S3 Block Public Access already enforces network restrictions.

Answer: B. VPC controls do not restrict direct API calls to S3 since S3 is accessed through a public API endpoint, and bucket policies must be reviewed separately.

Q2. An organization encrypts all production EBS volumes. A cloud security audit discovers that an EBS snapshot of a production database is accessible to external AWS accounts. Which principle does this scenario violate?

- A) A. Volume storage encryption automatically applies to all derived snapshots and prevents external sharing.
- B) B. Snapshot permissions are governed independently of the source volume, and snapshot access controls must be audited separately.
- C) C. External snapshot access is always permitted when the snapshot is encrypted with a customer-managed key.
- D) D. EBS snapshots are stored in the same bucket as the production data and inherit the volume's IAM policies.

Answer: B. Snapshot permissions are governed independently of the source volume, and snapshot access controls must be audited separately.

Q3. Which statement correctly distinguishes the primary security defense required for object storage compared to volume storage?

- A) A. Object storage requires network firewall rules; volume storage requires IAM policies.
- B) B. Object storage is secured at the API and identity layer; volume storage is secured at the instance, file system, and encryption layer.
- C) C. Both storage types have the same security model because both ultimately store data on physical disks.
- D) D. Volume storage requires bucket policies; object storage requires operating system access controls.

Answer: B. Object storage is secured at the API and identity layer; volume storage is secured at the instance, file system, and encryption layer.

Q4. A practitioner discovers that a developer committed an S3 access key pair into a private code repository eight months ago. The key is still active. What is the most appropriate immediate remediation?

- A) A. Make the repository private to prevent further exposure and monitor for any suspicious activity.
- B) B. Rotate the key within the next scheduled maintenance window to avoid disrupting active services.
- C) C. Immediately revoke the access key, audit CloudTrail for unauthorized access using that key, and replace static key-based access with IAM role-based authentication.
- D) D. Change the S3 bucket policy to deny all access from the compromised key's IP address range.

Answer: C. Immediately revoke the access key, audit CloudTrail for unauthorized access using that key, and replace static key-based access with IAM role-based authentication.

Reflection Questions

1. Consider a cloud environment you are familiar with: can you identify which storage types are in use and confirm that the controls applied match the access model of each type?
2. If your organization uses object storage, when was the last time bucket policies and sharing settings were audited? What process would detect a misconfigured public bucket within hours rather than months?
3. What is the current state of volume snapshot permissions in your environment? Is there a documented process for reviewing snapshot sharing settings, separate from the volume encryption review?
4. Where in your organization might long-lived access keys exist for object storage access? What would it take to migrate those to role-based, short-lived credentials?
5. Think about the orphaned volume risk: does your organization have a process for detecting and disposing of detached volumes that may contain sensitive data from decommissioned workloads?

Key Takeaways

- Object storage uses a flat namespace and HTTP API access, not file-system paths or directory hierarchies — the access model is fundamentally different from traditional storage.
- Volume storage provides block-level access to the OS, behaving like a virtual hard disk and used primarily for databases and workloads requiring low-latency, high-throughput I/O.
- The access model determines the security model: object storage is secured at the IAM and policy layer; volume storage is secured at the instance, encryption, and snapshot governance layer.
- Bucket misconfiguration — particularly public read access — is the most common and consequential threat to object storage, and can be mitigated with account-level Block Public Access controls and automated policy auditing.
- Volume snapshot permissions are governed independently of the source volume and must be audited as a distinct security control, not assumed to inherit the volume's protections.
- Long-lived IAM access keys used to access object storage APIs are a persistent risk that should be replaced with role-based, short-lived credential models wherever possible.
- Orphaned volumes in dynamic cloud environments may retain sensitive data and must be tracked, classified, and disposed of through a defined lifecycle policy.
- VPC network controls are insufficient as the primary defense for object storage because the storage API is internet-facing; identity and policy controls are the correct perimeter.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Log into your cloud console this week and run a check on all object storage buckets: confirm Block Public Access is enabled at the account level and that no bucket grants public read access.
7. Review the permissions of the five most recent volume snapshots in your environment — confirm they are restricted to your account only and that no unintended cross-account sharing is active.
8. Identify any IAM access keys in use by applications for object storage access and open a ticket this week to migrate those workloads to IAM role-based authentication with STS credentials.
9. Enable API-level logging (e.g., CloudTrail S3 data events or equivalent) on any object storage bucket holding sensitive or regulated data, if not already active.